PASS Data Community Summit

Host redgate

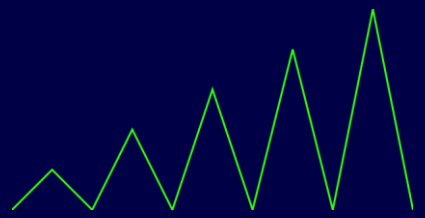
Database Security Session

Your MSSQL environment IS VULNERABLE

and I can prove it

v.2026.11

Fabiano Amorim
Chief Tech Advisor - PowerTuning



About Me

Connect with me on Linkedin



<speaker>

Fabiano Amorim

Chief tech advisor at PowerTuning

</speaker>

about_me.sql

```
SELECT [About me:]
FROM (VALUES
      ('Fabiano Amorim'),
      ('Data Platform MVP since 2011'),
      ('fabiano.amorim@powertuning.com.br | @mcflyamorim'),
      ('Chief tech advisor - PowerTuning'),
      ('red-gate.com/simple-talk/author/fabiano-amorim'))
AS Tab([About me:])
```

Connect

- @mcflyamorim
- fabianonevesamorim@hotmail.com

Blog & award

- blogfabiano.com
- Most Valuable Professional since 2011
- Most Valuable Security Researcher 2026

MSSQL CVEs

CVE-2025-53727, CVE-2025-47954, CVE-2025-59499, CVE-2026-26116, CVE-2026-47295, CVE-2026-55002, CVE-2026-66820, CVE-2026-66819, CVE-2026-77487, CVE-2026-77480, CVE-2026-77483, CVE-2026-73028, CVE-2026-66818, CVE-2026-66816, CVE-2026-84010, CVE-2026-116715, CVE-2026-118110...

Agenda

Presentation Overview & Structure



Foundations & Concepts

01 About me

02 Secure by Default

03 Common Vulnerabilities

Offensive Operations

04 Demo: Triggers (CVE-2026-66818)

05 Demo: Cross-DB Ownership and tempdb

06 Demo: Untrusted Backup Restores

07 Demo: SQL Injection (pwd crack)

Defense & Conclusion

09 Defensive Controls & Best Practices

10 Q&A

Secure by Default

"Secure by default" isn't the same as secure enough.

SQL Server is often described as “secure by default” but real incidents show that default settings can expose unnecessary attack surfaces if not constrained.

Common Vectors: System procedures, cross-DB ownership on system DBs, SQL Agent jobs, and TRUSTWORTHY on msdb (all enabled by default).

Reference

“Secure by default: What’s new in SQL Server 2025 security”
techcommunity.microsoft.com/blog/sqlserver/**secure-by-default**...



Vulnerabilities

Proving your MSSQL is vulnerable



THREAT_ASSESSMENT::LEVEL_HIGH

Your instance is effectively compromised if any of the following scenarios are true:

Note: I'm listing only some vectors; other vulnerabilities exist.

01 **Privileged Roles**
Login is a member of **db_owner** role on tempdb, msdb or ~~any user database~~ (fixed on last CU).

02 **Untrusted Restores**
Performing database restores from untrusted sources (External Vendors, Dev/Test).

03 **TempDB Exposure**
Login with permissions to execute DDL and DML operations on **tempdb** .

04 **Unsafe Maintenance**
Maintenance jobs (e.g., Update Stats) running without protection from trigger permission hijacking.

05 **You created a new login**
Yes, you read it right… no special/extra permissions, that's all I need.

I'll disclose three more distinct vulnerabilities tomorrow during my session with Andreas, ***including one that was ~~fixed~~ supposed to be fixed in today's Security Update release (10 AM PST)****. "Inside Real SQL Server Breaches: Privilege Escalations and How to Stop It" November 11 | 2:15–3:30 PM | Room 405 Kachess*

LIVE DEMO

Demo - Triggers

Attack from inside (the evil user)

Trigger Permission Hijack

Escalating from **db_owner** to **sysadmin** through trigger abuse.

1

The classic permission hijack

Hijack permission from update statistics maintenance job.

sqlcmd - db_owner_login

```
➜ ~ CREATE TRIGGER [dbo].[tr_hack]
    ON DATABASE FOR  DDL_DATABASE_LEVEL_EVENTS
    AS
    -- Malicious payload here...
    CREATE LOGIN [MyNewSa] WITH PASSWORD=...;
    ALTER SERVER ROLE sysadmin ADD MEMBER [MyNewSa];
    ...
➜ ~ GO
```

<PrivEsc />

References: Erland Sommarskog - Permission Hijacking and MS - Manage trigger security

DEMO - From CONTROL *in one database* to sysadmin

A database-scoped principal crosses the privilege boundary through sys.sp_MScheck_join_filters, which performs DDL inside the user database while running under an elevated context.

CVE-2026-66818

Class
Elevation of privilege

Affected
Any user database

Impact
Full instance compromise

ATTACK PATH

sp_link_publication ⟶ sp_MSrepltrigpreparecert

01 **Initial foothold**
Attacker holds CONTROL or db_owner on any user database

02 **Call sp_link_publication**
Replication - entry point, accessible from any database

03 CRITICAL ELEVATED CONTEXT
sp_MSrepltrigpreparecert
Performs alter certificate inside caller's database - runs as dbo / effectively sa

04 INTERCEPT DDL TRIGGER FIRES
ON DATABASE FOR DDL_DATABASE_LEVEL_EVENTS
Trigger body runs attacker-controlled T-SQL using the elevated exec context - no explicit impersonation needed

05 **PRIVILEGE BOUNDARY CROSSED** server compromise
CREATE LOGIN [NewSysAdminLogin] · ALTER SERVER ROLE [sysadmin] ADD MEMBER

PERSPECTIVE

Attacker

- sp_link_publication **can be called by default**, no need to actually use replication
- One user database is enough
  - CONTROL or db_owner on any user database (tempdb, an app DB)
- A single internal call is the pivot
  - Invoke an internal replication proc, no special permissions, no app-side warnings
- Outcome persists despite errors
  - Side effects survive the failing call (Msg 3609) sysadmin membership already executed

Fixed on Sep GDR - msrc.microsoft.com/update-guide/vulnerability/CVE-2026-66818

PASS Data Community Summit
Host redgate

LIVE DEMO

Demo - Cross DB Ownership

Tempdb - The public toilet of SQL Server

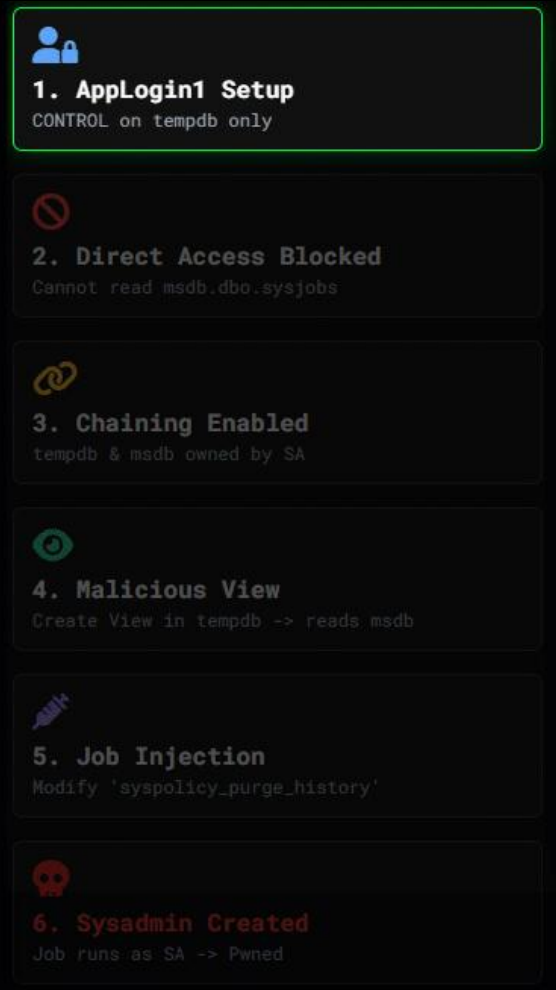
Attack Vector

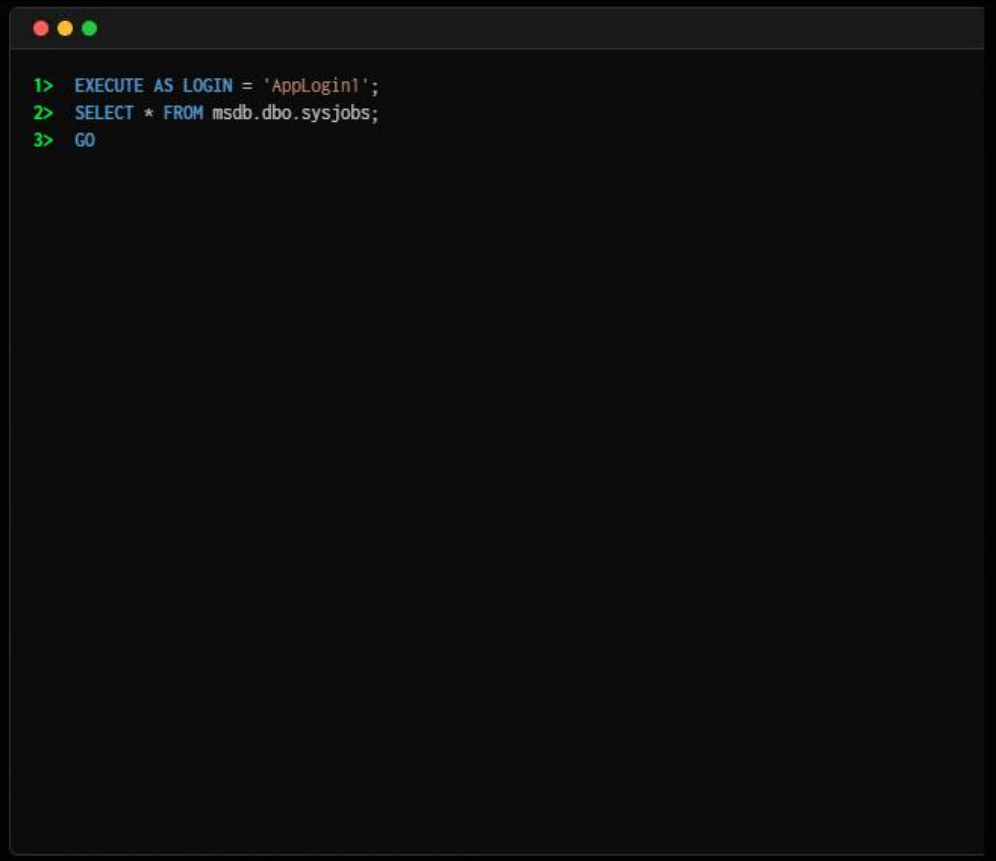
Exploring **tempdb** and ownership chaining to bypass privilege boundaries across databases.



Explored feature:
DB **Ownership Chaining**

Impact:
Privilege Escalation





HIGH RISK

Demo - Restoring Untrusted Backups

"Trust me when I say, you should trust no one!"

- SQL Injection vulnerability via *an internal process*
  - Escalate from **db_creator** to **sysadmin**

MICROSOFT SAYS

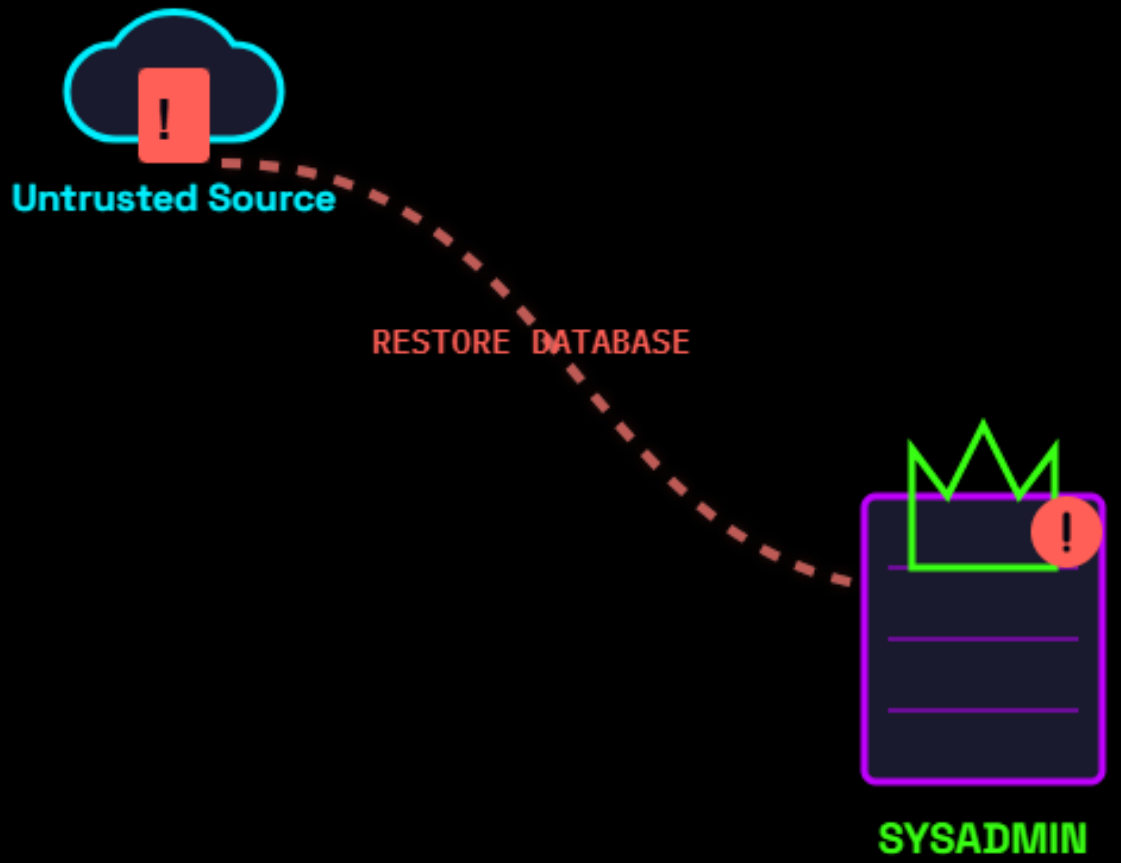
"By-design behavior"

Security risk of restoring backups from untrusted sources
https://learn.microsoft.com/en-us/sql/relational-databases/backup-restore/back-up-and-restore-of-sql-server-databases?#security-risk-of-restoring-backups-from-untrusted-sources

MSRC

After careful review, this case is assessed as **None** severity. This case does not meet Microsoft's definition of a security vulnerability...

The reported behavior in sqllang!TruncateFTIndexDocIdInternalTable is ***not a vulnerability*** because the affected code path is only reached when a specific internal full-text object exists, and that object cannot be created in the production/public cloud environment without an undocumented trace flag or feature switch that is not available. Since normal full-text activity does not create the required internal object, the dynamic TRUNCATE TABLE statement is never constructed or executed against a full-text indexed table, so the described bracket-injection path **cannot be triggered under supported configurations**.



LIVE DEMO

Demo - SQL Injection

Data Exfiltration

Vulnerability Detail

Exploiting a known injection flaw to escalate privilege.

`sys.sp_help_spatial_geography_histogram`

Fixed on Azure, SQL Server 2022 CU20 (KB5063814) and all supported versions.

Impact

Leak sensitive table data

Decrypt encrypted modules

Crack password hashes (hashcat)



Reference

Red Gate article: SQL Injection in SQL Server
https://www.red-gate.com/simple-talk/featured/sql-injection-sql-server%E2%80%90dbaas/

Defensive Controls

Mitigation Strategy

Reduce attack surface & prevent privilege escalation

Principle of Least Privilege

Ensure users only have access to what they need. Revoke unnecessary permissions like VIEW SERVER STATE, or if a user doesn't need access to sys.sp_help_spatial_geography_histogram, it should not have access to it.

Active Monitoring & Audit

Implement strict auditing on role membership changes and DDL events.

Patch Management

Install latest CUs and security fixes as soon as possible to close known vulnerability paths.

Code Review & SQLi

Review modules for SQL injection risks. Tool: github.com/mcflyamorim/SQLInjectionCheck

PowerTuning

We can help you, contact me for more details



Follow up guidance

https://learn.microsoft.com/en-us/sql/relational-databases/security/security-center-for-sql-server-database-engine-and-azure-sql-database

Your feedback is important to us



Evaluate this session at:

passdatacommunitysummit.com/evaluations



Q & A

Questions? Let's talk.

powertuning
Power SQL Security Assessment
Assess your environment before an attacker does.
powersqlsecurity.com/en/

Connect with me on Linkedin